SECCIÓN 5.5

Análisis de eventos de red y DNS

Temas de esta sección:

- Una consulta DNS ≠ una conexión exitosa
- Una conexión no siempre muestra el dominio
- Proceso asociado a la conexión: el campo más importante
- Beaconing: legítimo vs sospechoso
- Dominios sospechosos y servicios legítimos abusados
- NXDOMAIN y dominios aleatorios
- Correlación proceso + DNS + conexión

Errores conceptuales frecuentes y la perspectiva correcta:

DNS Query → conexión confirmada	DNS indica intento de resolución. No confirma que la conexión se estableció ni que hubo transferencia.
Port 443 → tráfico legítimo	HTTPS solo indica que el puerto está en uso o que la comunicación va cifrada. No determina la intención.
Conexión bloqueada → caso cerrado	El bloqueo reduce el riesgo inmediato. Revisar si hubo actividad previa, otros intentos o componentes ejecutados.
Dominio conocido → actividad normal	GitHub, Drive, Dropbox pueden ser abusados. La reputación del dominio no define la intención del proceso.
Volumen alto → exfiltración	Un volumen alto puede ser backup, sincronización o trabajo normal. Hay que validar proceso, destino y contexto.

5.5 | Beaconing: legítimo vs sospechoso

Beaconing es comunicación periódica repetitiva. El contexto define si es legítimo o sospechoso:

```
# Beaconing LEGÍTIMO
Host: IT-ADM-02
Process: edr_agent.exe
Path: C:\Program Files\SecurityVendor\
Destination: console.securityvendor.com
Frequency: Every 60 seconds
Signed: Yes
Deployment: Documented and approved
```

Proceso firmado y conocido
Ruta en Program Files
Destino de proveedor de seguridad
Despliegue documentado
Frecuencia esperada del agente

```
# Beaconing SOSPECHOSO
Host: USER-LAP-088
Process: update.exe
Path: C:\Users\Public\
Destination: cdn-health-check.net
Frequency: Every 60 seconds
Signed: No  |  Created: Today
Parent Process: powershell.exe
```

Proceso sin firma
Ruta pública de usuario
Destino desconocido y nuevo
Proceso padre: PowerShell
Creado el mismo día

La frecuencia periódica por sí sola no es la señal.
La señal está en la combinación: proceso padre, ruta, firma, destino y contexto operativo.

No todo dominio sospechoso tiene mala reputación. Algunos usan infraestructura legítima:

Señales de dominio sospechoso

- First seen: hoy o hace pocos días
- Sin historia de uso en el entorno
- Nombre aleatorio tipo: cdn-health-check.net
- Baja o sin reputación en Threat Intel
- Registrado recientemente
- Hosting en infra genérica sin relación con el servicio
- Subdominios muy largos con posibles datos codificados

Validar: ¿qué proceso generó la consulta? ¿Hubo conexión exitosa después?

Servicios legítimos abusados

- GitHub / GitLab: payload en repo público
- Google Drive / OneDrive: instrucciones en archivo
- Discord / Telegram: bot C2
- Pastebin / Hastebin: configuración descargada
- Slack / Teams webhooks: datos exfiltrados
- Twitter / X: instrucciones en DMs o posts

⚠ El dominio tiene buena reputación pero el proceso que conecta es sospechoso. Enfocarse en el proceso, no en el destino.

update.exe sin firma en Public conectando a github.com periódicamente requiere el mismo análisis que si conectara a un dominio desconocido.

5.5 | NXDOMAIN y dominios aleatorios: posible DGA

Un patrón de muchos NXDOMAIN con nombres aleatorios puede indicar un algoritmo de generación de dominios:

```
# Ejemplo de patrón DGA (Domain Generation Algorithm)
Host: FIN-LAP-022  |  Time: 10:05-10:07

DNS Query: akd92kdkd-check.com       → NXDOMAIN
DNS Query: plq77smmx-update.net      → NXDOMAIN
DNS Query: xhb33mkp-verify.org       → NXDOMAIN
DNS Query: cdn-sync-files-check.net  → RESOLVED
DNS Query: mz91xkq-health.com        → NXDOMAIN

480 queries in 15 minutes | 1 resolved
```

Qué es DGA y por qué importa:

- DGA genera muchos dominios automáticamente
- El malware prueba hasta encontrar uno activo
- La mayoría responden NXDOMAIN (no existen aún)
- Solo el dominio activo del día responde
- Muy difícil de bloquear preventivamente
- El malware se conecta al que resolvió

Qué buscar en SOC:

- Alto volumen de NXDOMAIN desde un host
- Nombres con patrón aleatorio (no diccionario)
- Un solo dominio que resuelve entre muchos NXDOMAIN
- Proceso que genera las queries sin usuario activo
- Conexión posterior al dominio que resolvió
- Correlacionar con alertas de proceso o archivo en el mismo host

5.5 | Correlación proceso + DNS + conexión: la secuencia completa

Un buen análisis de red no mira cada evento por separado:

10:04	**EDR**	WINWORD.EXE → powershell.exe (Office ejecuta PS)
10:05	**DNS**	Query: files-check-update.net → 185.22.14.90
10:05	**Firewall**	Connection: 185.22.14.90:443 — Action: Allowed
10:06	**EDR**	File Created: C:\Users\Public\update.exe (por powershell.exe)
10:07	**EDR**	Process Created: update.exe (ejecutado desde ruta pública)
10:08	**Firewall**	update.exe → sync-check-cloud.net cada 60 segundos

Hipótesis: posible ejecución inicial con descarga de payload, ejecución posterior y comunicación periódica externa.
La alerta de red aislada (paso 3) es ambigua. La secuencia completa cuenta una historia clara.